exec.txt
TXT 30.92KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 12 web pages

Este arquivo é **malware** (um worm de propagação automatizada). Ele não é uma ferramenta legítima de operação e manutenção; trata-se de um script de ataque projetado especificamente para invadir servidores, espalhar-se horizontalmente e estabelecer controle backdoor.

🔍 Análise Passo a Passo

1. Coleta de credenciais e varredura de alvos

O script contém senhas fracas embutidas (como `LeitboGi0ro`, `123@@@`) e utiliza `masscan` para varrer em larga escala as portas 22 e 5522 da internet, procurando hosts que permitam login SSH. Ele verifica ativamente os IPs de destino através de `https://sou.pp.ua/check_ip.php` para evitar repetição de infecção. [7]

2. Propagação automática e backdoor

Após fazer login com sucesso em um host, ele envia o arquivo `bendi.py` e executa operações:

- Instala silenciosamente o `komari-agent` com os parâmetros `https://sexy.pp.ua`.
- Envia um "relatório de implantação" para o atacante através do bot do Telegram (`7431501378:AAHT...`).
- Registra o IP invadido no banco de dados de controle do atacante (`add_ip.php`). [2] [7]

3. Persistência e camuflagem

O script cria os serviços systemd `scan-runner` e `file-monitor`, configurando `Restart=always` para garantir que, mesmo após reinicialização ou eliminação do processo, o malware seja reiniciado automaticamente. O nome do serviço imita serviços normais do sistema para dificultar a detecção.

4. Natureza do Komari Agent

Embora o Komari seja originalmente uma ferramenta legítima de monitoramento, nesta

cadeia de ataque ele é usado como **canal C2 (Command and Control)**. Relatórios de segurança apontam que o Komari possui capacidade de execução remota integrada (Web SSH), e após ser implantado por invasores, torna-se um "painel de botnet" que permite ao atacante executar comandos remotamente, transformando o servidor em um "host zumbi".

⚠️ Se você executou este arquivo

Recomenda-se tomar medidas imediatas:

1. **Desconecte a rede**: isole o servidor da internet.
2. **Limpe os serviços**: execute `systemctl stop scan-runner file-monitor` e remova os arquivos de serviço correspondentes em `/etc/systemd/system/`.
3. **Remova os arquivos**: exclua os diretórios `/root/.s/`, `/root/.a/`, `/opt/monitor/` e os scripts relacionados.
4. **Altere as senhas**: altere imediatamente a senha root e as chaves SSH deste servidor e de todos os servidores com relações de confiança.
5. **Verifique os logs**: verifique se há conexões externas desconhecidas e processos suspeitos.

12 web pages

Qual é a categoria principal deste malware?

Found 13 web pages

A categoria principal deste malware é **worm de botnet** (também pode ser chamado de "worm de propagação SSH" ou "botnet de propagação automática").

Ele não é um vírus ou trojan tradicional, mas sim um **worm autônomo com capacidade de propagação automática**. A cadeia completa de comportamento é a seguinte:

1. **Varredura e ataque automáticos**: Utiliza `masscan` para escanear a internet em busca de servidores com SSH aberto e, em seguida, realiza tentativas de login por força bruta usando senhas fracas embutidas (como `LeitboGi0ro`, `123@@@`). [11]
2. **Infecção e controle**: Após invadir com sucesso um host, ele instala o agente de controle remoto Komari (disfarçado de serviço do sistema) para estabelecer um

backdoor persistente e se comunicar com o servidor C2 do atacante (`sexy.pp.ua`), transformando o host em um "host zumbi" (bot) controlável remotamente. [11]

3. **Propagação horizontal contínua**: O script é implantado no host invadido, que então usa o próprio host como trampolim para continuar escaneando e atacando outros alvos, formando um ciclo de autorreplicação "força bruta → infecção → força bruta novamente". [11]

Em resumo, seu objetivo principal é expandir continuamente o número de hosts zumbis controláveis, construindo assim uma botnet com capacidade de execução remota de comandos.

13 web pages